

Aletheia: Uma Arquitetura de Atestação Verificável para a Promoção de Versões de Sistemas de IA

Cauã Pereira da Silva
Faculdade de Informática e
Administração Paulista (FIAP)
São Paulo, Brasil

Pedro Henrique Lamin Rodrigues
Faculdade de Informática e
Administração Paulista (FIAP)
São Paulo, Brasil

Felipe Pinheiro Bahia Putti
Faculdade de Informática e
Administração Paulista (FIAP)
São Paulo, Brasil

Versão pública da proposta da startup Aletheia, desenvolvida na trilha Startup One do curso de Engenharia de Software da FIAP ON, 2026. O documento descreve o problema, a arquitetura de referência e as decisões de posicionamento do projeto. O procedimento estatístico que produz o veredicto, o esquema completo do documento assinado e o protocolo de recalibração do avaliador foram omitidos, e constam da documentação técnica interna.

Resumo—Sistemas construídos sobre modelos de linguagem não são determinísticos. A mesma entrada produz saídas diferentes a cada execução, o que invalida o pressuposto de repetibilidade sobre o qual a engenharia de testes foi construída. A troca de modelo também não é opcional, porque fornecedores aposentam versões com prazo de aviso curto, e a organização migra sem evidência de que a versão nova não regrediu. Este documento descreve o Aletheia, uma arquitetura de referência em três camadas (medição comparativa entre versões, atestação assinada do resultado e admissão por política no pipeline do cliente), que transpõe para sistemas de IA a cadeia de custódia já usada em segurança de cadeia de suprimentos de software, formada por assinatura de artefato, proveniência de construção e política de admissão. As duas metades do problema já existem em separado. A contribuição está na ligação entre elas, com uma medição que declara o próprio limite de sensibilidade e um documento assinado que um terceiro verifica sem acesso ao banco de dados de quem o emitiu. O texto registra ainda duas decisões de recorte. A primeira é o veredicto intermediário de inconclusivo, emitido quando o efeito observado é menor do que a medição conseguia detectar. A segunda é a recusa de bloquear o deploy do cliente. O levantamento de trabalhos relacionados reúne cinco frentes que tratam partes vizinhas do problema, e nenhuma delas cobre a ligação descrita aqui.

Palavras-chave—garantia de sistemas de IA, atestação verificável, cadeia de custódia de software, política de admissão, teste de regressão em sistema estocástico, proveniência de artefato, in-toto, Sigstore, AI Act.

I. INTRODUÇÃO

A. Contexto

Organizações já operam sistemas baseados em modelos de linguagem em funções sensíveis, como atendimento a cliente, leitura de documento e triagem de paciente. Cada troca de modelo, alteração de instrução ou adição de ferramenta ao agente muda o comportamento do sistema. Não existe hoje mecanismo aceito para afirmar, antes de a mudança entrar em produção, que ela não piorou o serviço.

Software determinístico não tem esse problema. Uma linha muda, a suíte de testes roda e o resultado é verde ou vermelho. O mesmo teste executado duas vezes produz o mesmo veredicto. Sistemas construídos sobre modelos de linguagem quebram esse pressuposto. A mesma pergunta gera resposta diferente a cada execução, e a diferença entre duas execuções da mesma versão pode superar a diferença entre duas versões distintas.

A troca de modelo tampouco é opcional. Fornecedores aposentam versões antigas periodicamente, com prazo de aviso curto, e a organização que depende de uma versão precisa migrar dentro da janela oferecida. Na prática migra sem evidência, e descobre a regressão pelo cliente que reclama.

B. Definição do problema

O problema se resume a uma pergunta que nenhuma ferramenta responde hoje de forma auditável.

“Prove que a versão de IA que está atendendo seu cliente agora foi testada antes de subir: contra o quê, com qual avaliador e autorizada por quem.”

Três categorias de ferramenta chegam perto e param antes. Plataformas de avaliação registram os testes em banco de dados que elas mesmas podem alterar. Um registro que o emissor pode reescrever não tem valor probatório diante de um terceiro.

Plataformas de segurança e observabilidade examinam o que acontece em produção, depois da decisão de promover a versão, e não a verificação que a autorizou. Sistemas de integração e entrega contínua registram que uma etapa foi executada, sem registrar o que ela concluiu, e não impedem que alguém remova a etapa do fluxo.

O caso é de cadeia de custódia. Em software tradicional o problema já está resolvido, com maquinário maduro. Assinatura de artefato, proveniência de construção e política de admissão são prática padronizada [3]–[7]. Falta a transposição desse maquinário para sistemas de IA, onde o artefato não é determinístico e o avaliador é ele mesmo um modelo que muda com o tempo.

C. Contribuição e recorte deste documento

São quatro as contribuições. A primeira é uma arquitetura de referência em três camadas, que separa quem mede, quem assina e quem decide (Seção III). A segunda é o conjunto de propriedades que um veredicto precisa satisfazer para ter defesa sobre um sistema estocástico, incluindo a necessidade de um terceiro estado além de aprovado e reprovado (Seção IV). A terceira é um modelo de confiança em que a verificação da prova não depende de quem a emitiu (Seção V). A quarta é o registro das decisões de recorte de escopo e do contexto regulatório que as motiva (Seção VI).

Esta é a versão pública de um projeto em desenvolvimento. Três elementos foram omitidos: o procedimento estatístico que produz o veredicto, o esquema campo a campo do documento assinado e o protocolo de recalibração do avaliador. As propriedades que esses elementos precisam satisfazer estão descritas no texto. A implementação que as satisfaz fica na documentação interna do projeto.

II. TRABALHOS RELACIONADOS

Cada camada desta proposta já foi atacada isoladamente, por grupos de pesquisa e por empresas. Nenhum trabalho identificado junta as três. A Tabela I resume o levantamento.

A. Assinatura e proveniência de artefatos de aprendizado de máquina

O esforço da OpenSSF em torno de assinatura de modelos, com participação de Google e NVIDIA, aplica a artefatos de aprendizado de máquina o mesmo maquinário de assinatura, bundle de proveniência e log de transparência usado em cadeia de suprimentos de software [3], [5], [6]. Este projeto se apoia nessa base. A pergunta que ela responde é outra. A assinatura garante que o arquivo é aquele. Ela nada afirma sobre o comportamento do arquivo.

B. Admissão por atestação

Tan, Singer e Anagnostopoulos [1] propõem um portão de promoção sensível a atestação, que valida claims de treinamento e de release ligados criptograficamente ao artefato antes de ele entrar em ambiente confiável. A arquitetura é a mesma adotada aqui, com claims verificáveis em in-toto e Sigstore e admissão por política. A diferença está no conteúdo do claim. O trabalho trata claims de cadeia de suprimentos, e a avaliação de comportamento entra como verificação de fumaça, sem versão de referência e sem tratamento de significância. Os autores registram que riscos em nível de

comportamento exigem validação específica da tarefa. O artigo é de posição e não traz implementação avaliada.

C. Atestação de propriedade de modelo

O Laminator [2] assina, dentro de um ambiente de execução confiável em hardware, o vínculo entre um modelo e a acurácia que ele obtém em um conjunto de dados, e produz cartões de propriedade verificáveis. A garantia é mais forte que a das outras frentes e tem dois custos. O primeiro é a dependência de hardware confiável no caminho de execução. O segundo é o objeto da prova, que é uma propriedade de uma versão isolada, e não a diferença entre a versão candidata e a versão em produção.

D. Plataformas de avaliação com portão em integração contínua

Ferramentas comerciais de avaliação já oferecem tratamento estatístico no portão, bloqueio de release e trilha de auditoria [12]. O limite delas é de custódia. O registro fica no banco de dados do próprio fornecedor da ferramenta, que pode alterá-lo, e recai no caso recusado na Seção I.

E. Suítes de governança de IA

Plataformas de governança [13] e os arcabouços normativos que elas operacionalizam [10], [11] cobrem classificação de risco, documentação obrigatória e fluxo de conformidade regulatória. O produto delas é a descrição do processo. Nenhuma gera prova sobre a execução de uma verificação concreta em uma versão concreta.

TABELA I
TRABALHOS RELACIONADOS: O QUE CADA FRENTE RESOLVE E O QUE DEIXA DE FORA

Frente	O que resolve	O que fica de fora
Assinatura de artefatos de aprendizado de máquina OPENSSF MODEL SIGNING, SIGSTORE, IN-TOTO [3], [5], [6]	Assinatura, bundle de proveniência e log de transparência para modelos e artefatos associados.	Assina o arquivo. Não afirma nada sobre o comportamento do artefato assinado, nem sobre a diferença entre duas versões dele.
Portão de admissão por atestação TAN ET AL., FSE '26 [1]	A mesma arquitetura adotada aqui, com claims verificáveis em in-toto e Sigstore e admissão por política antes da promoção.	Trata claims de cadeia de suprimentos. A avaliação entra como verificação de fumaça, sem versão de referência e sem tratamento de significância. Artigo de posição, sem implementação avaliada.
Atestação de propriedade de modelo LAMINATOR, CODASPY '25 [2]	Vincula, dentro de ambiente de execução confiável em hardware, um modelo à acurácia medida em um conjunto de dados.	Depende de hardware confiável no caminho de execução. Prova uma propriedade de uma versão isolada, e não a diferença entre a versão candidata e a que está em produção.
Plataformas de avaliação com portão em CI FERRAMENTAS COMERCIAIS DE EVAL [12]	Tratamento estatístico no portão, bloqueio de release e trilha de auditoria da execução dos testes.	O registro fica no banco de dados do próprio fornecedor, que pode alterá-lo. Relatório de execução, sem valor probatório diante de um terceiro.
Suítes de governança de IA PLATAFORMAS DE GRC PARA IA [13], ISO/IEC 42001 [10], NIST AI RMF [11]	Classificação de risco, documentação obrigatória e fluxo de conformidade regulatória.	Descreve o processo. Não produz prova sobre a execução de uma verificação concreta em uma versão concreta.

F. A lacuna

As duas metades do problema já existem, resolvidas em separado. De um lado há medição comparativa com tratamento estatístico. De outro há prova criptográfica que um terceiro confere sem confiar em quem a emitiu. Falta a ligação entre as duas, isto é, uma medição cujo resultado, com o limite de sensibilidade declarado junto, esteja preso por criptografia a um artefato verificável de forma independente.

III. ARQUITETURA DE REFERÊNCIA

O Aletheia tem três camadas. As duas primeiras rodam do lado de quem emite a prova. A terceira roda no ambiente do cliente. A Fig. 1 mostra o caminho de uma mudança até a promoção.

A. Camada de medição

A camada de medição executa um conjunto de casos sobre a versão candidata e sobre a versão de referência em produção, e compara as duas em três eixos: regressão de qualidade da resposta, variação de custo de execução e abertura de brecha de comportamento indevido. O conjunto de casos cresce com o uso. Falhas observadas em produção entram como casos

permanentes, por ingestão de rastros em formato aberto de observabilidade.

B. Camada de atestação

Toda execução da camada de medição gera um documento assinado, tenha ela aprovado ou reprovado a versão candidata. O veredicto fica dentro do payload assinado, e não em um campo de banco de dados ao lado dele. O desenho do documento segue uma regra. O que não está dentro do payload assinado não está provado, por mais que apareça em um painel. A consequência para o produto é que nada exibido na interface pode depender de informação que um terceiro não consiga reconstruir a partir das atestações emitidas.

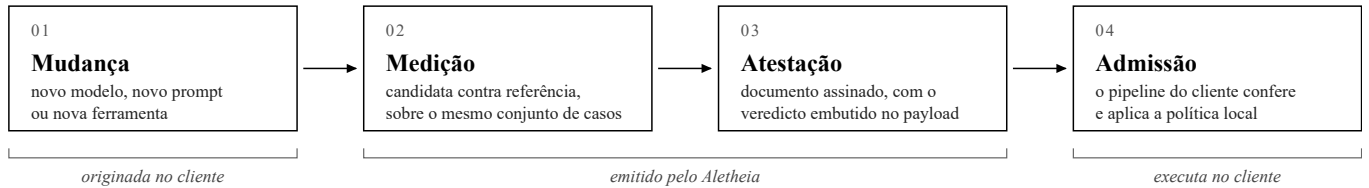


Fig. 1. Caminho de uma mudança, da alteração no sistema do cliente até a decisão de promoção. A camada de admissão roda no pipeline do próprio cliente, não na infraestrutura de quem emite a prova.

D. Separação de responsabilidades

A arquitetura separa três perguntas que costumam ser tratadas como uma só. A pergunta “foi testado?” cabe à camada de admissão, e a resposta é obrigatória, porque sem atestação válida a versão não sobe. A pergunta “passou?” cabe ao veredicto dentro da atestação, e a resposta fica com a política do cliente, que pode promover uma versão reprovada desde que o aceite do risco fique registrado. A pergunta “quem impede?” cabe ao pipeline do cliente. O Aletheia não bloqueia deploy. Ele recusa assinar uma aprovação.

IV. VEREDICTO SOBRE SISTEMA ESTOCÁSTICO

A. Por que um portão binário falha

Um limiar fixo aplicado sobre a média de uma execução única, que é o comportamento usual das ferramentas existentes, dispara alarme falso por variância natural do sistema medido. O efeito prático é conhecido de quem já manteve um portão de qualidade em integração contínua. Um portão que dispara sem motivo é desativado em poucas semanas, e um portão desativado não protege nada. A confiabilidade do veredicto é requisito de operação do produto.

B. Três veredictos

O Aletheia emite três estados. Passou, quando nenhuma piora acima do efeito detectável foi observada. Falhou, quando há piora consistente e acima do que a variação natural explicaria. Inconclusivo, quando a diferença observada é menor do que aquela amostra conseguia detectar.

O terceiro estado é o que distingue a proposta das ferramentas existentes, que tratam ausência de sinal como aprovação. Uma prova que afirma mais do que a medição mediu não tem valor probatório.

C. Propriedades exigidas do procedimento

O procedimento que produz o veredicto não está descrito nesta versão do documento. As propriedades que ele precisa satisfazer, sim:

- distinguir regressão real de variação natural do sistema medido, em vez de comparar médias de execuções isoladas.

C. Camada de admissão

No momento do deploy, o pipeline do próprio cliente confere a assinatura da atestação, confere que o artefato prestes a subir é o mesmo descrito nela e aplica a política local da organização. Sem atestação válida, a versão não sobe. Com atestação válida e veredicto de falha, a decisão fica com o cliente, que pode promover a versão assim mesmo. Nesse caso o registro guarda quem aceitou o risco. Existe um caminho de exceção para emergência, com justificativa escrita e registro no mesmo log inapagável.

- declarar, dentro da própria prova, o menor efeito que aquela amostra era capaz de detectar, de modo que o leitor saiba o que o resultado não afirma.
- controlar a taxa de falso positivo quando vários critérios são avaliados na mesma execução.
- tratar o custo de execução do portão como parâmetro explícito, porque um portão caro é desativado.
- manter comparabilidade entre atestações emitidas em épocas diferentes, dado que o avaliador é ele mesmo um modelo sujeito a aposentadoria pelo motivo descrito na Seção I.

As duas últimas propriedades costumam ficar de fora das ferramentas existentes, e decidem se o sistema continua em uso depois do primeiro trimestre.

V. MODELO DE CONFIANÇA

A pergunta que define o valor da prova é de quem o verificador precisa confiar para aceitá-la. A Fig. 2 descreve a fronteira.

A. Autossuficiência da prova

Nada aparece na interface do produto que um terceiro não consiga reconstruir a partir das atestações assinadas, sem acesso ao banco de dados de quem as emitiu. Um painel que funciona como fonte de verdade recai no caso recusado na Seção II.

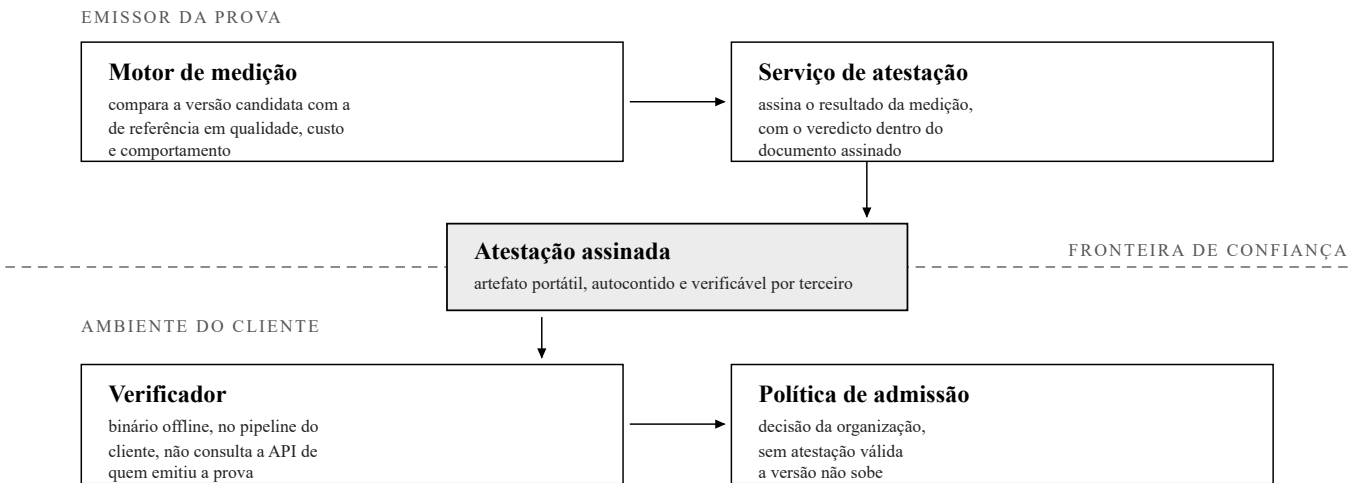
B. Verificação independente

A verificação fica a cargo de um binário pequeno, que roda offline, mora no pipeline do cliente e não conversa com a API de quem emitiu a prova. Ele confere a assinatura, confere que o artefato prestes a subir é o mesmo descrito na atestação e aplica a política local. A propriedade buscada com esse desenho é de longo prazo. Se a empresa que emitiu as atestações encerrar as atividades, as provas já emitidas continuam verificáveis.

C. Reuso de padrões abertos

Formato e assinatura reusam in-toto, Sigstore e log de transparência [3], [4], o mesmo maquinário que a indústria usa para proveniência de construção, em produção e sob auditoria

pública. Um cartório de assinatura próprio consumiria uma fase inteira do projeto e produziria garantia mais fraca.



O lado de baixo não depende da disponibilidade do lado de cima. A prova já emitida continua verificável se o emissor encerrar as atividades.

Fig. 2. Fronteira de confiança. A atestação atravessa a fronteira como artefato autocontido, e a decisão de promover fica com o cliente.

D. O ativo defendido é o formato

O mapa dos trabalhos relacionados também mostra o risco competitivo do projeto. A camada de medição é copiável. Se uma plataforma de avaliação existente acoplar assinatura ao portão que já vende, a diferenciação técnica dura pouco. O ativo que o projeto defende é o formato, com predicado publicado, verificador aberto e adoção por terceiros. Um

formato adotado por terceiros vira infraestrutura. Um motor fechado vira funcionalidade que um concorrente reimplementa.

VI. RECORTE DE ESCOPO E CONTEXTO REGULATÓRIO

A. O que o sistema não faz

O projeto trata a ampliação de escopo como o risco principal desta fase. A Tabela II registra o que ficou de fora e por quê.

TABELA II
RECORTE DE ESCOPO

Fora do escopo	Justificativa
Detecção de injeção de prompt em tempo real	Problema em aberto, sem mecanismo que imponha fronteira de privilégio de forma confiável. O sistema faz regressão, isto é, verifica se um ataque antes recusado voltou a funcionar na versão candidata.
Qualquer componente no caminho da requisição	Um proxy adiciona latência e vira ponto único de falha do produto do cliente.
Plataforma de observabilidade própria	O sistema consome os rastros que o cliente já emite em formato aberto.
Modelo próprio ou ajuste fino de modelo	Fora da competência da equipe e do prazo do projeto.
Orquestração multinuvem e registro em blockchain	Alternativas mais simples atendem ao mesmo requisito, com menos superfície de operação.
Cartório de assinatura próprio	Padrões abertos já auditados cumprem esse papel em produção [3], [4]. Construir do zero consumiria uma fase inteira do projeto e produziria garantia mais fraca.
Bloqueio de deploy	Quem barra é a política do cliente, no processo de entrega dele. Uma ferramenta que derruba deploy é desativada, e a atestação deixa de ser emitida.

B. A recusa de bloquear o deploy

A última linha da Tabela II é a decisão de posicionamento com maior efeito sobre o produto. O sistema não derruba o deploy de ninguém. Ele recusa assinar uma atestação de aprovação, e quem barra é a política que o cliente já roda no próprio processo de entrega. O raciocínio é de permanência da ferramenta dentro da organização. Uma ferramenta que impede uma entrega na sexta-feira é desativada na segunda, e a prova que ela produzia desaparece com ela.

C. Contexto regulatório

O Regulamento (UE) 2024/1689, o AI Act [8], estabeleceu obrigações de verificação e documentação para sistemas de IA de alto risco. O Regulamento (UE) 2026/1744 [9], publicado

no Jornal Oficial da União Europeia em julho de 2026, alterou os prazos dessas obrigações. Sistemas autônomos do Anexo III passam a ser exigidos em 2 de dezembro de 2027, e sistemas associados a legislação de produto, do Anexo I, em 2 de agosto de 2028. Uma atestação assinada de verificação prévia é o tipo de artefato que esse regime demanda, e as duas datas caem dentro do horizonte de desenvolvimento do projeto.

VII. CONCLUSÃO

Este documento descreveu a arquitetura de referência do Aletheia, formada por medição comparativa entre a versão candidata e a versão em produção, atestação assinada com o veredicto dentro do payload e admissão por política executada no pipeline do cliente. As duas metades da solução já existem e

estão maduras. A contribuição está na ligação entre elas, com duas decisões de desenho que a tornam utilizável. A primeira é o veredicto de inconclusivo, que impede a prova de afirmar mais do que a medição mediu. A segunda é a recusa de bloquear o deploy, que mantém a ferramenta instalada.

O detalhamento do procedimento estatístico, o esquema completo do documento assinado, o protocolo de recalibração do avaliador e o plano de validação por fases constam da documentação técnica do projeto, disponível mediante contato com os autores.

REFERÊNCIAS

- [1] Z. Tan, J. Singer e C. Anagnostopoulos, “Attesting LLM pipelines: enforcing verifiable training and release claims,” in *Companion Proc. 34th ACM Int. Conf. Foundations of Software Engineering (FSE '26)*, Montreal, Canadá, jun. 2026. arXiv:2603.28988. [Online]. Disponível em: arxiv.org/abs/2603.28988.
- [2] V. Duddu, O. Järvinen, L. J. Gunn e N. Asokan, “Laminator: verifiable ML property cards using hardware-assisted attestations,” in *Proc. 15th ACM Conf. Data and Application Security and Privacy (CODASPY '25)*, Pittsburgh, PA, EUA, jun. 2025. [Online]. Disponível em: doi.org/10.1145/3714393.3726492.
- [3] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola e J. Cappsos, “in-toto: providing farm-to-table guarantees for bits and bytes,” in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, EUA, ago. 2019. [Online]. Disponível em: in-toto.io.
- [4] Z. Newman, J. S. Meyers e S. Torres-Arias, “Sigstore: software signing for everybody,” in *Proc. ACM SIGSAC Conf. Computer and Communications Security (CCS '22)*, Los Angeles, CA, EUA, nov. 2022. [Online]. Disponível em: sigstore.dev.
- [5] Open Source Security Foundation, “Model signing: assinatura criptográfica para modelos de aprendizado de máquina,” OpenSSF, 2025. [Online]. Disponível em: openssf.org.
- [6] Google Open Source Security Team, “Case study: Google secures machine learning models with Sigstore,” OpenSSF Blog, jul. 2025. [Online]. Disponível em: openssf.org/blog.
- [7] Open Source Security Foundation, “Supply-chain Levels for Software Artifacts (SLSA), v1.0,” 2023. [Online]. Disponível em: slsa.dev.
- [8] União Europeia, “Regulamento (UE) 2024/1689 do Parlamento Europeu e do Conselho, que estabelece regras harmonizadas em matéria de inteligência artificial,” *Jornal Oficial da União Europeia*, jun. 2024. [Online]. Disponível em: eur-lex.europa.eu.
- [9] União Europeia, “Regulamento (UE) 2026/1744, que altera os prazos de aplicação das obrigações relativas a sistemas de IA de alto risco,” *Jornal Oficial da União Europeia*, jul. 2026. [Online]. Disponível em: eur-lex.europa.eu.
- [10] International Organization for Standardization e International Electrotechnical Commission, “ISO/IEC 42001:2023, Information technology, artificial intelligence, management system,” ISO, Genebra, Suíça, 2023.
- [11] National Institute of Standards and Technology, “Artificial Intelligence Risk Management Framework (AI RMF 1.0),” NIST AI 100-1, Gaithersburg, MD, EUA, jan. 2023. [Online]. Disponível em: nist.gov.
- [12] Braintrust Data, Inc., “Avaliação de aplicações de IA e portão de release em integração contínua,” documentação do produto, 2026. [Online]. Disponível em: braintrust.dev.
- [13] Credo AI, “Plataforma de governança de inteligência artificial,” documentação do produto, 2026. [Online]. Disponível em: credo.ai.